

개선요구

제 목 개인정보처리시스템 접속 기록 보관 및 점검 체계 미비

관 계 부 서 ◆◆팀

내 용

1. 업무 개요

◆◆팀은 「사무기구 업무분장 및 인계·인수 규칙」에 따라 연구회의 개인정보보호 업무를 총괄하고 있으며, 「개인정보보호법」 제29조에 따라 개인정보 내부 관리계획 수립, 개인정보처리시스템 접속기록 보관·점검 등 개인정보의 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하고 있습니다.

2. 관계법규 및 판단기준

「개인정보보호법」 제28조에 따르면 개인정보처리자는 개인정보를 처리함에 있어서 개인정보가 안전하게 관리될 수 있도록 임직원, 파견근로자, 시간제근로자 등 개인정보처리자의 지휘·감독을 받아 개인정보를 처리하는 자(이하 “개인정보 취급자”)의 범위를 최소한으로 제한하고, 개인정보취급자에 대하여 적절한 관리·감독을 하여야 합니다. 같은 법 제29조에 따라 연구회는 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 합니다. 이때, 같은 법 시행령 제30조 제1항 제1호 및 제5호에 따라 내부 관리계획을 수립·시행 및 점검할 때는 개인정보 침해사고 발생에 대응하기 위한 접속 기록의 보관 및 위조·변조 방지를 위한 조치를 포함하여야 합니다. 특히, 개인정보를

처리할 수 있도록 체계적으로 구성한 데이터베이스시스템(이하 “개인정보처리 시스템”)에 접속한 자의 접속 일시, 처리 내역 등 접속 기록의 저장·점검 및 이의 확인·감독에 대한 조치를 이행하기 위해 필요한 세부사항을 포함하여야 합니다.¹⁾

이에 연구회에서는 2018년부터 매년 ‘개인정보 내부 관리계획(안)’을 수립하고 이행 실태를 연 1회 이상 점검·관리하고 있으며, 2023.6.1.부로 연구회 내규 「개인정보보호업무기준」을 제정하였고, 2024년 5월 이후부터 개인정보취급자가 개인정보처리시스템에 접속한 기록을 점검할 계획을 안내하는 등 연구회가 취급하는 개인정보를 체계적으로 관리하고 있습니다.²⁾

‘2025년 연구회 개인정보 내부 관리계획(안)’에 따르면 연구회는 개인정보가 위·변조 및 도난, 분실되지 않도록 개인정보처리시스템 접속 기록을 2년 이상 안전하게 보관·관리하여야 합니다.³⁾⁴⁾ 또한, 개인정보처리시스템 관리자는 개인정보취급자가 개인정보처리시스템에 접속하여 개인정보를 처리했던 기록을 월 1회 점검하여야 하며, 점검 시 [표 1]과 같이 비정상적인 개인정보 처리 행위에 해당하는 경우에는 개인정보취급자로부터 그 사유를 확인해야 합니다.

[표 1] 비정상적인 개인정보 처리 행위로서 그 사유를 확인해야 하는 경우

구 분	내 용
다운로드 정보주체의 수	1,000명 이상의 정보주체에 대한 개인정보를 다운로드 한 경우
일정기간 내 다운로드 횟수	개인정보취급자가 1시간 내 다운로드가 20건 이상일 경우
다운로드 수행 시점	새벽시간(0시~6시), 휴무일(공휴일, 주말 포함) 등 업무시간 외 개인정보를 다운로드 한 경우

1) 연구회의 개인정보처리시스템에는 경영지원시스템(MIS), 출연(연)·전문가 포털시스템 등이 있음

2) 개인정보처리시스템 접속기록 점검 시행 안내(◆◆팀-306, 2024. 6. 18.)

3) 2025년도 개인정보 내부관리계획(안) 보고(◆◆팀-90, 2025. 3. 18.)

4) 접속기록: 개인정보취급자의 계정, 접속 일시, 접속지 정보(IP 등), 처리한 정보주체 정보, 수행업무 등 그 밖에 접근권한의 오·남용 및 정보유출 여부를 검증하기 위해 필요하다고 판단되는 정보

한편, 연구회는 개인정보취급자의 개인정보처리시스템 접속 기록을 체계적으로 보관하고 효율적으로 점검·관리하기 위해서 2023.3.14. 이후 개인정보 종합관리 솔루션 소프트웨어를 구매하여 업무에 활용하고 있습니다.⁵⁾

3. 감사결과 확인된 문제점

2025년 개인정보처리시스템 접속 기록을 점검한 결과를 살펴본 결과, 개인정보 취급자가 1시간 이내에 20건 이상의 개인정보를 다운로드하거나, 새벽 시간대(자정부터 6시까지) 또는 공휴일·주말을 포함한 휴무일 등 업무시간 외에 개인정보를 다운로드한 경우가 있었음에도 이에 대한 다운로드 사유를 확인하지 않은 사실이 [표 2]와 같이 확인되었습니다.

[표 2] 2025년 개인정보처리시스템 접속 기록 중 개인정보 다운로드 사유를 확인하지 않은 내역⁶⁾

일자	시간	업무시간 외 여부	소속	개인정보 취급자명	시스템명	다운로드한 개인정보 내용 및 건수
1.4	20:08	휴일	(생략)		경영지원시스템(MIS)	휴대폰번호 1
1.7	9:23~10:19	-			경영지원시스템(MIS)	휴대폰번호 31, 1
1.7	15:01~15:03	-			경영지원시스템(MIS)	휴대폰번호 35
1.12	23:40	휴일			경영지원시스템(MIS)	휴대폰번호 1
1.16	00:45	새벽시간			경영지원시스템(MIS)	휴대폰번호 1
1.20	15:37~16:09	-			경영지원시스템(MIS)	휴대폰번호 21
1.20	15:42~16:26	-			경영지원시스템(MIS)	휴대폰번호 29
1.20	20:16~21:02	-			경영지원시스템(MIS)	휴대폰번호 22
1.21	18:22~19:02	-			경영지원시스템(MIS)	휴대폰번호 20

이처럼 비정상적으로 개인정보를 다운로드한 경우에 해당함에도 그 사유를 확인하는 절차가 이행되지 않는다면 개인정보처리시스템 접속 기록을 점검하는 실효성을 떨어뜨리게 되며 개인정보 침해사고 발생 시 조기에 대응할 수 있는 연구회의 관리·감독 기능이 약해질 수밖에 없습니다.

5) 연구회 개인정보 종합보안관리 솔루션 구매계획(안)(◆◆팀-762, 2022.12.22.)

개인정보 종합보안관리 솔루션(이지서터 UBI SAFER-PSM) MASTER 외 1건 구매검수신청(230314-001-804, 2023.3.14.)

6) '25년 1월 개인정보처리시스템 접속기록 점검 결과 보고(◆◆팀-36, 2025. 2. 27.)

한편, 그간 점검한 개인정보처리시스템 접속 기록에서 개인정보 처리 업무 유형을 확인한 결과, 2025년 1월까지 개인정보를 처리한 업무 유형은 등록, 수정, 삭제, 조회, 다운로드 등으로 다양하게 구분되어 접속 기록이 관리되고 있었으나 그 이후 2월부터는 접속 기록이 '조회' 유형으로만 관리되고 있는 사실이 [표 3]과 같이 확인되었습니다.

[표 3] 2024년 4분기 및 2025년 개인정보 처리 업무 유형별 건수

구분	2024년			2025년											
	10월	11월	12월	1월	2월	3월	4월	5월	6월	7월	8월	9월	10월	11월	12월
다운로드	678	629	1,126	1,323	-	-	-	-	-	-	-	-	-	-	-
등록	1,905	8,658	12,004	2,970	-	-	-	-	-	-	-	-	-	-	-
삭제	33	25	73	233	-	-	-	-	-	-	-	-	-	-	-
수정	967	2,722	2,377	1,106	-	-	-	-	-	-	-	-	-	-	-
조회	120,108	211,439	161,037	63,281	210,009	119,709	222,796	129,521	104,376	110,120	105,816	193,478	146,763	79,984	181,427
출력	-	-	3	-	-	-	-	-	-	-	-	-	-	-	-

※ 월별 개인정보처리시스템 접속기록 점검결과 보고자료 재가공('24년 10월 ~ '25년 12월)

앞서 연구회는 개인정보처리시스템 접속 기록을 체계적·효율적으로 관리하기 위해서 개인정보 종합관리 솔루션을 도입하여 자동화된 방식으로 접속 기록을 점검하고 있었다고 하나, 2025년 기록된 개인정보 처리 업무 유형을 살펴볼 때 점검 양상에 대한 일관성을 담보하기 어려우므로 이에 대한 점검 결과를 신뢰 하기가 어렵습니다.

따라서 연구회는 개인정보취급자가 개인정보를 안전하게 처리하고 있는지 주기적으로 점검·관리하는 업무 체계를 재검토하여 개인정보 처리에 대한 내부 통제를 강화할 필요가 있습니다.

관계부서 의견

관계부서에서는 현재 개인정보처리시스템에서 개인정보 다운로드 시 그 사유를 확인하는 절차가 마련되어 있지 않아 개인정보처리시스템 접속 기록의 보관·점검 체계를 고도화할 필요가 있다고 하였습니다. 또한, 2025년 2월부터 개인정보처리시스템 접속 기록 점검 시 ‘조회’ 유형만 도출되는 현상에 대해서는 개인정보 종합관리 솔루션의 기능상 보완이 필요한 것으로 판단하여 관련 기능에 대한 패치를 적용할 예정이라고 하였습니다.

향후 개인정보처리시스템 접속 기록 점검에 관한 사항을 포함하여 개인정보 내부관리계획을 재검토하고 개선할 계획을 밝히며, 연구회의 실정에 맞게 개인정보를 철저히 보호하고 관리·운영하겠다고 하였습니다. 이를 위해 개인정보 보호·관리에 필요한 예산을 확보하고 개인정보보호 전담 인력을 충원하는 등의 관리 역량을 강화하기 위해 노력할 것이라고 하였습니다.

조치할 사항

이사장께서는 연구회가 취급하는 개인정보를 안전하게 관리할 수 있도록 개인정보처리시스템 접속 기록의 보관 및 점검 체계를 재검토하시고 개인정보의 안전성 확보에 대한 체계적이고 실효성 있는 조치 방안을 마련하시기 바랍니다. [개선]